

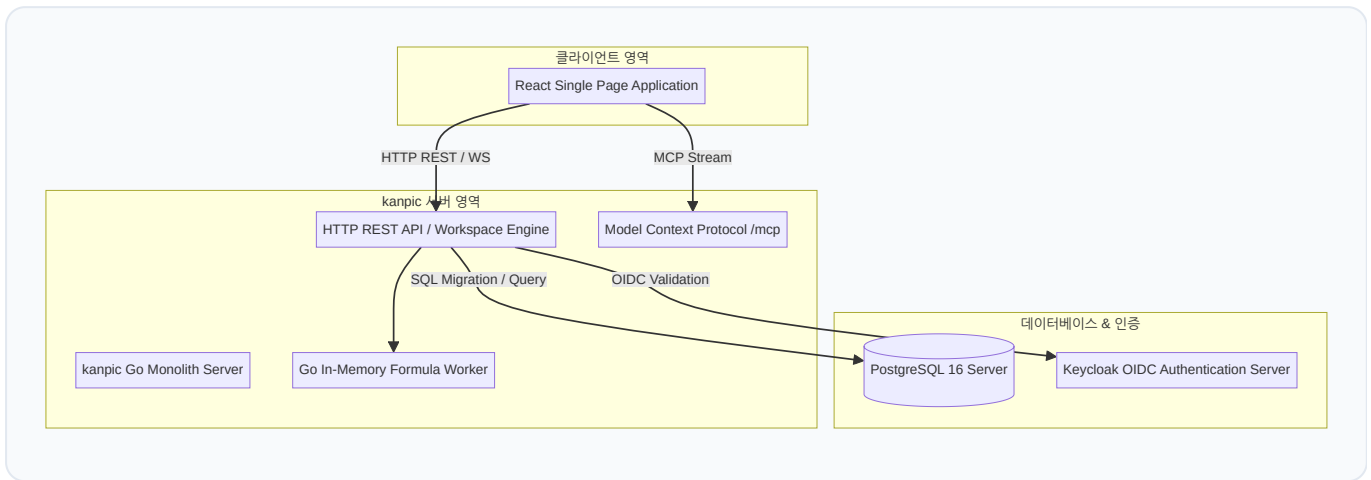
kanpic 관리자 가이드 (System Administrator Manual)

- **제품명:** kanpic 데이터 협업 플랫폼
- **시스템 버전:** v0.242.0
- **문서 버전:** v2.0
- **최종 수정일:** 2026년 9월 11일
- **문서 분류:** 시스템 관리자 및 DevOps 엔지니어용 통합 운영 매뉴얼 (System Administrator Manual)
- **함께 보는 문서:** 화면을 쓰는 방법은 [사용자 가이드](USER_GUIDE.md)에 있습니다. 여기서는 겹쳐 적지 않습니다.

이 문서의 화면 캡처는 모두 v0.242.0 을 실제로 띄워 1440×900 에서 찍은 것이며, 등장하는 이름·이메일·워크북은 전부 예시용 가짜 데이터입니다.

1. 개요 및 시스템 아키텍처

본 문서는 **kanpic 플랫폼**의 설치, 배포, 보안 설정, Keycloak OIDC 통합, 데이터베이스 마이그레이션 및 일상 운영 관리를 담당하는 시스템 관리자를 위한 기술 가이드입니다.



2. 배포 및 아키텍처 특성

kanpic은 인프라 복잡도를 극소화하고 폐쇄망 환경에서의 안정성을 극대화하기 위해 **Redis-Free 인메모리 단일 바이너리/컨테이너** 아키텍처를 채택하고 있습니다.

- **Embedded Assets:** React 프론트엔드 정적 파일(`web/dist`), CA 인증서, 타임존 데이터, DDL 마이그레이션 SQL 파일이 Go 바이너리 내부(`embed.FS`)에 집적되어 별도의 외부 파일 의존성이 없습니다.
- **Server-Authoritative Storage:** PostgreSQL 16을 유일한 영구 저장소로 활용하며, 모든 워크북 변경사항은 JSONB 형태의 델타 변경 이력으로 기록됩니다.

2.1 구성 요소

구성 요소	무엇인가	필수	비고
<code>kanpic</code> 컨테이너	Go 단일 바이너리. REST·WebSocket·MCP·정적 자산을 한 프로세스가 낸다	필수	기본 8080/tcp
PostgreSQL	유일한 영구 저장소. 워크북·설정·로그·API 키·세션이 모두 여기 있다	필수	16 이상(compose 예시는 <code>postgres:17-alpine</code>)
Keycloak(OIDC)	조직 계정 로그인	선택	없으면 bootstrap 관리자 로그인만 쓴다
사내 LLM Gateway	Workbook Agent(AI)	선택	OpenAI 호환 <code>/v1</code>
사내 SMTP 릴레이	공유·댓글·멘션·지켜보기 알림 메일	선택	
프레젠테이션 서비스 (Ptium)	선택 범위로 슬라이드 만들기	선택	

Redis, 메시지 브로커, 별도의 파일 저장소는 쓰지 않습니다.

자원	값
포트	컨테이너 8080/tcp 하나. 외부에는 리버스 프록시의 443 만 연다
볼륨	애플리케이션 컨테이너는 상태가 없다. PostgreSQL 데이터 디렉터리만 볼륨으로 잡는다
바깥으로 나가는 연결	PostgreSQL, (설정한 경우) Keycloak · LLM Gateway · SMTP · 프레젠테이션 서비스 · <code>external.allowed_hosts</code> 와 <code>handoff.peers</code> 에 적은 곳뿐

2.2 릴리즈 자산으로 설치

GitHub Release 의 `kanpic-vX.Y.Z.tar.gz` 는 Docker 이미지 아카이브입니다. 폐쇄망에서는 이 파일과 `.sha256` 만 옮기면 됩니다. 런타임에 인터넷이 필요하지 않습니다.

```
# 1. 받은 파일이 온전한지 확인하고 이미지를 올린다
VERSION=v0.242.0
sha256sum -c "kanpic-${VERSION}.tar.gz.sha256"
gzip -dc "kanpic-${VERSION}.tar.gz" | docker load

# 2. compose 파일을 쓴다 (이미지 태그를 방금 올린 버전으로)
cat > compose.yaml <<'YAML'
name: kanpic
services:
  api:
    image: kanpic:v0.242.0
    environment:
      POSTGRES_DSN: postgres://kanpic:${POSTGRES_PASSWORD}@postgres:5432/kanpic?sslmode=disable
      BOOTSTRAP_ADMIN_ID: ${BOOTSTRAP_ADMIN_ID}
      BOOTSTRAP_ADMIN_PASSWORD: ${BOOTSTRAP_ADMIN_PASSWORD}
    ports: ["8080:8080"]
    depends_on:
      postgres: { condition: service_healthy }
    restart: unless-stopped
  postgres:
    image: postgres:17-alpine
    environment:
      POSTGRES_DB: kanpic
      POSTGRES_USER: kanpic
      POSTGRES_PASSWORD: ${POSTGRES_PASSWORD}
    healthcheck:
      test: ["CMD-SHELL", "pg_isready -U kanpic -d kanpic"]
      interval: 2s
      timeout: 3s
      retries: 15
    volumes: [kanpic-postgres:/var/lib/postgresql/data]
volumes:
  kanpic-postgres:
YAML

# 3. 최초 관리자 계정과 DB 비밀번호를 넘겨 띄운다
# (셀 기록에 남지 않게 read 로 받거나 배포 도구의 비밀 저장소를 쓴다)
read -rs POSTGRES_PASSWORD; export POSTGRES_PASSWORD
read -rs BOOTSTRAP_ADMIN_PASSWORD; export BOOTSTRAP_ADMIN_PASSWORD
export BOOTSTRAP_ADMIN_ID=admin
docker compose up -d

# 4. 댔는지 확인한다
curl -fsS http://localhost:8080/healthz
curl -fsS http://localhost:8080/api/v1/version
```

스키마는 서버가 시작할 때 `migrations/` 를 순서대로 적용하므로 따로 할 일이 없습니다. 브라우저로 `http://<서버>:8080` 을 열어 `BOOTSTRAP_ADMIN_ID` 로 로그인하면 관리자 콘솔이 열립니다. 이후 설정은 모두 `/admin` 화면에서 하고, 바꿀 때마다 설정 버전이 생깁니다.

> `BOOTSTRAP_ADMIN_ID` 와 `BOOTSTRAP_ADMIN_PASSWORD` 는 둘 다 넣거나 둘 다 빼야 합니다. > 하나만 넣으면 서버가 시작하지 않습니다(`BOOTSTRAP_ADMIN_ID and BOOTSTRAP_ADMIN_PASSWORD must be configured together`). > 둘 다 빼면 로그인 없이 최초 설정을 할 수 있는 개방형 모드가 되므로, 운영 배포에서는 반드시 지정합니다.

2.3 환경 변수 전수

서버가 읽는 환경 변수는 이것이 전부입니다(`cmd/api/main.go`). 나머지 서비스 설정은 환경 변수가 아니라 관리자 콘솔에 저장되며, 그 목록은 3.5 절의 설정 키 표에 있습니다.

이름	기본값	필수	설명
<code>POSTGRES_DSN</code>	없음	필수	PostgreSQL 접속 문자열. 없으면 서버가 <code>POSTGRES_DSN is required</code> 를 남기고 종료합니다. 예: <code>postgres://kanpic:<비밀번호>@postgres:5432/kanpic?sslmode=require</code>
<code>BOOTSTRAP_ADMIN_ID</code>	빈 값	선택 (짝)	로컬 관리자 로그인 아이디. 예: <code>admin</code>
<code>BOOTSTRAP_ADMIN_PASSWORD</code>	빈 값	선택 (짝)	로컬 관리자 비밀번호. 충분히 길게 정하고 배포 도구의 비밀 저장소로 주입합니다
<code>PORT</code>	<code>8080</code>	선택	서버가 열 포트

3. 관리자 콘솔 (`/admin`) 및 주요 관리 기능

관리자 계정으로 로그인 후 상단 프로필 메뉴의 **[관리자 콘솔]** 또는 `/admin` 경로로 이동하여 시스템 전반을 관리할 수 있습니다.

!관리자 콘솔 개요 — 사용자·부서·워크북·공유 규모 카드와 점검이 필요한 항목 목록](images/guide/admin-overview.png)

왼쪽 목록이 콘솔의 전부입니다: **개요 · 시스템 설정 · 사용자 및 역할 · 워크북 거버넌스 · 부서 및 공유 · AI 호출 이력 · 알림 메일 · 방문자 추적 · 서버 로그 · API 키 현황 · 시스템 상태**. 각 화면은 `/admin?tab=<이름>` 주소를 그대로 가지므로 북마크하거나 링크로 넘길 수 있습니다.

3.1 관리자 개요와 워크북 거버넌스

`/admin` 은 **개요** 화면으로 시작합니다. 사용자·부서·워크북·공유 규모를 카드로 보여 주고, 점검이 필요한 항목(링크가 있는 모든 사용자에게 공개, 조직 전체 공개, 소유자가 없거나 정지된 워크북, 대기 중인 액세스 요청)을 클릭하면 해당 목록으로 바로 이동합니다.

워크북 거버넌스 화면은 관리자가 소유하지 않은 워크북까지 포함해 전체 목록을 보여 줍니다.

필터	용도
전체	활성 워크북 전체
링크 공개	<code>링크가 있는 모든 사용자</code> 범위로 열려 있는 워크북
조직 전체	<code>조직 내 모든 사용자</code> 범위로 열려 있는 워크북
소유자 문제	소유자가 비어 있거나 정지된 계정인 워크북
잠든 워크북	1년 이상 손대지 않은 워크북
휴지통	삭제되어 복원 가능한 워크북

[워크북 거버넌스 — 거르게(전체·링크 공개·조직 전체·소유자 문제·잠든 워크북·휴지통)와 워크북마다 소유자·공유 범위·시트 수·최근 수정](images/guide/admin-workbooks.png)

각 행에서 **공개 해제**(링크 액세스를 제한됨으로 되돌리기), **소유권** 이전, **휴지통** 이동, 휴지통 항목의 **복원**을 실행할 수 있습니다.

조직 차원의 상한은 시스템 설정으로 강제합니다.

- `sharing.max_link_access` : 허용할 최대 링크 액세스 범위(`restricted` , `organization` , `anyone`). 이 범위를 넘는 공유 요청은 REST·MCP 모두에서 거부됩니다.
- `sharing.default_link_access` : 새 워크북의 기본 링크 액세스.

3.2 사용자 및 역할 관리

[사용자 및 역할 — 전체 사용자·관리자·정지된 계정 수와 사용자마다 역할·부서·워크북 수·마지막 접속·상태](images/guide/admin-users.png)

`/admin` → **사용자 및 역할** 에서 계정 상태와 kanpic 역할을 관리합니다. 신원 자체는 OIDC 공급자(또는 bootstrap 로그인)가 소유하고, kanpic은 접근 통제에 필요한 상태만 보관합니다.

- **자동 등록**: 로그인한 사용자는 사용자 ID, 표시 이름, 이메일과 마지막 접속 시각으로 자동 등록됩니다. 아직 로그인하지 않은 사람은 **사용자 등록** 으로 미리 만들어 두고 역할·부서를 배정할 수 있습니다.
- **계정 정지**: 정지하면 즉시 모든 세션이 삭제되고 이후 모든 API·화면 요청이 `403 account_suspended` 로 차단됩니다. 정지 해제하면 다시 로그인할 수 있습니다. 자기 자신은 정지할 수 없습니다.
- **kanpic 역할**: 사용자에게 역할을 부여하면 워크북 공유 창의 **역할** 대상으로 즉시 사용할 수 있습니다. OIDC 토큰의 역할과 kanpic 역할은 함께 평가되며 둘 중 하나만 일치해도 권한이 부여됩니다. 한 사용자는 최대 50개 역할을 가집니다.
- **관리자 지정**: 사용자 상세의 **관리자로 지정** 은 `kanpic-admin` 역할(또는 `auth.oidc.admin_roles` 의 첫 역할)을 부여합니다. 이 역할을 가진 사용자는 콘솔과 모든 워크북에 접근할 수 있습니다. **관리자 해제** 로 회수하며, 자신의 관리자 역할은 잠금 방지를 위해 스스로 회수할 수 없습니다.
- **세션 종료**: **모든 세션 종료** 는 해당 사용자의 브라우저 세션을 모두 삭제합니다.

부서 관리자 위임

전역 관리자가 **부서 및 공유** 화면에서 부서마다 **부서 관리자** 를 지정할 수 있습니다.

부서 관리자는 **자기 부서와 그 아래 부서의 구성원 계정** 만 다룹니다. 부서가 나뉘어도 맡은 사람이 바뀌지 않도록 아래 부서까지 봅니다 — 팀이 둘로 갈라졌다고 관리자가 절반을 못 보게 되면 위임이 끊긴 것을 아무도 알아채지 못합니다.

열어 준 것	열지 않은 것
맡은 구성원 목록 보기	워크북 소유권 이전
계정 정지·해제, 메모	개요(조직 전체 숫자)
kanpic 역할 부여·회수	워크북 거버넌스
모든 세션 종료	설정·로그·API 키·AI 정책·메일
	사용자 등록·일괄 등록

- **소유권 이전을 열지 않은 이유**: 자료를 옮기는 일이기 때문입니다. 잘못 옮기면 조용히 사고가 나고, 되돌리려면 누가 무엇을 가졌는지 다시 맞춰야 합니다.

- **개요를 열지 않은 이유:** 조직 전체 규모가 새어 나갑니다. 부서 관리자는 자기 부서만 알면 됩니다. 사용자 목록도 **같은 구성원만** 보입니다.
- **이메일은 바꿀 수 없습니다.** 알림 메일은 디렉터리에 적합한 이메일로 갑니다 — 지켜보기 알림에는 바뀐 칸이, 멘션에는 댓글이 실려 나갑니다. 부서 관리자가 그것을 바꿀 수 있으면 구성원의 알림을 조용히 자기 쪽으로 돌릴 수 있고, 받는 사람은 메일이 끊긴 것을 한참 뒤에야 압니다. 이름과 메모는 그대로 고칠 수 있습니다.
- **관리자 계정은 다룰 수 없습니다.** 같은 부서 구성원 중에 전역 관리자가 섞여 있어도 정지·세션 종료·조회가 되지 않고, **사용자 목록에도 나오지 않습니다.** 부서 하나를 맡겼을 뿐인데 관리자를 콘솔에서 잠가 조직의 관리 자체를 멈출 수 있으면 위임이 아닙니다.
- **관리자 역할은 건드릴 수 없습니다.** 부서 관리자가 구성원에게 `kanpic-admin` 을 얹으면 전역 관리자를 하나 만들어 내는 셈이고, 자기 자신을 막아 둔 것도 그 한 걸음으로 우회됩니다. 회수도 같은 범위 밖이므로 함께 막습니다. 그 밖의 kanpic 역할은 그대로 부여·회수할 수 있습니다.
- **자기 자신은 다룰 수 없습니다.** 스스로 정지를 풀거나 역할을 엮을 수 있으면 위임이 아니라 승격입니다.
- **부서 관리자는 전역 관리자만 지정합니다.** 부서 관리자가 스스로를 늘릴 수 있으면 위임이 아니라 승격입니다.
- 사용자 등록과 일괄 등록은 전역 관리자만 합니다. 새로 만든 사용자는 아직 어느 부서에도 없어, 만든 사람이 곧바로 볼 수 없기 때문입니다.
- **일괄 등록: 일괄 등록...** 에서 CSV를 붙여 넣거나 파일을 고르면 팀 하나를 한 번에 들일 수 있습니다.
- **머리글 줄이 있어야 합니다.** `user_id` (필수) · `display_name` · `email` · `note` 를 읽고, `사용자 ID` · `이름` · `이메일` · `메모` 로 적어도 됩니다. 자리로 읽으면 열 차례가 다른 파일을 말없이 엉뚱하게 읽어, 이름 칸에 이메일이 들어간 사용자가 스무 명 생깁니다.
- **먼저 미리 보여 줍니다.** 새로 만들 사람, 이미 있어 정보만 갱신될 사람, 건너뛴 줄을 줄마다 알려 줍니다. 사람을 여럿 만드는 일은 되돌리기 번거롭습니다.
- **같은 파일 안에 같은 아이디가 두 번** 나오면 뒤엎것으로 덮어쓰지 않고 몇 번째 줄과 겹치는지 짚어 줍니다. 어느 줄이 맞는지는 사람이 정해야 합니다.
- 한 줄이 잘못돼도 나머지를 버리지 않고, 무엇이 들어갔고 무엇이 안 들어갔는지 줄마다 돌려줍니다.
- 역할과 부서는 등록한 뒤 사용자별로 지정합니다.

! [사용자 일괄 등록 — 미리 보기가 줄마다 새로 만들·갱신·건너뛴을 알려 준다] (images/guide/admin-users-import.png)

- **잠든 계정 찾기:** 사용자 목록의 **잠든 계정만(90일)** 을 켜면 90일 넘게 들어오지 않은 계정만 보입니다. **한 번도 들어온 적 없는 계정도 잠든 것으로 셉니다** — 미리 등록해 두고 아무도 쓰지 않은 계정이 그대로 남는 일이 흔합니다. 개요 화면에도 수가 나옵니다.
- **가진 워크북 인수인계:** 사용자를 고르고 **가진 워크북 인수인계...** 를 누르면 그 사람이 소유한 워크북을 **모두** 보여 주고 한 번에 새 소유자에게 넘깁니다. 퇴사자가 마흔 개를 가지고 있어도 한 번입니다.
- 목록은 **자르지 않습니다.** 200개까지만 보여 주면 201번째 워크북은 넘겨지지 않은 채 남고 아무도 그것을 모릅니다.
- **휴지통에 있는 것은 넘기지 않고 몇 개인지 셉니다.** 되살린 뒤에 다시 넘기세요. 조용히 빼면 "다 넘겼다" 는 말과 남아 있는 워크북이 어긋납니다.
- 넘긴 것과 **넘기지 못한 것을 하나하나** 보여 줍니다. 절반만 넘어갔는데 "다 됐습니다" 라고 하면 남은 절반은 정지된 계정에 묶인 채 잊힙니다.
- **정지된 사람에게는 넘기지 않습니다.** 받은 사람도 손댈 수 없으므로 옮긴 것이 아니라 옮긴 척한 것이 됩니다.
- **이전 소유자를 편집자로 남기기** 를 켜면 인수인계 기간에 이전 담당자가 계속 볼 수 있습니다. 정지 전에 미리 넘길 때 씁니다.
- 워크북을 **하나씩** 넘기는 것은 워크북 거버넌스 화면에 그대로 있습니다. 기기 분실이나 권한 변경 직후에 사용합니다.
- **목록 정보:** 역할, 소속 부서, 소유 워크북 수, 마지막 접속 시각을 한눈에 확인하고 사용자·이메일·역할·부서로 검색합니다.

REST 계약은 `GET/POST /api/v1/admin/users` , `GET/PATCH /api/v1/admin/users/{userId}` , `POST /api/v1/admin/users/{userId}/roles` , `DELETE /api/v1/admin/users/{userId}/roles/{role}` , `DELETE /api/v1/admin/users/{userId}/sessions` 이며 모두 관리자 세션 또는 `admin.*` scope를 요구합니다.

> API 키는 소유자 계정을 따릅니다. 소유자가 정지되면 그 키로 보낸 요청도 함께 차단됩니다.

3.3 부서 계층 및 워크북 공유 통제

`/admin` → **부서 및 공유** 에서 조직의 부서 계층을 관리합니다. 부서는 워크북 공유의 기본 단위이므로 관리자만 변경할 수 있습니다.

!부서 및 공유 — 부서 수와 구성원 배치 수, 상위/하위 관계가 보이는 부서 목록](images/guide/admin-departments.png)

- **부서 생성**: 이름과 상위 부서를 지정합니다. 같은 상위 부서 아래에서는 이름이 중복될 수 없고 최대 8단계까지 중첩됩니다.
- **구성원 배치**: 사용자 ID 또는 이메일을 심표나 공백으로 구분해 한 번에 최대 200명까지 추가합니다. 대소문자는 구분하지 않습니다.
- **상위 부서 변경**: 자신의 하위 부서를 상위로 지정하는 순환 구조는 거부됩니다.
- **부서 삭제**: 하위 부서가 없어야 하며, 삭제 시 그 부서로 부여된 모든 워크북 공유가 함께 제거됩니다.

상위 부서에 공유하면 하위 부서 구성원까지 권한을 상속합니다. 예를 들어 `경영지원본부` 에 편집자 권한을 주면 `재무팀` , `인사팀` 구성원 모두가 편집자가 됩니다.

권한 판정은 소유자 → 관리자 → 개인 공유 → 부서 공유 → 역할 공유 → 링크 액세스를 모두 계산해 **가장 높은 권한**을 적용합니다. 관리자 역할(`auth.oidc.admin_roles`)을 가진 사용자는 감사와 복구를 위해 모든 워크북에 소유자 권한으로 접근하며, 이때 공유 창에는 `관리자 권한으로 접근 중입니다` 로 표시됩니다.

REST `GET /api/v1/departments` 와 MCP `spreadsheet.department.list` 는 모든 로그인 사용자가 사용할 수 있고(공유 대상 선택에 필요), 생성·수정·삭제·구성원 변경은 `admin.*` scope 또는 관리자 세션만 허용합니다.

3.4 개인 API 키 통제 및 회전 (Key Rotation)

- `/admin` → **API 키 현황** 에서 발급된 모든 Personal API Key 의 소유자·앞자리(Prefix)·scope·최근 사용·상태를 감사하고, 새어 나간 키를 즉시 **폐기** 할 수 있습니다. 키 원문은 어디에도 다시 표시되지 않습니다(데이터베이스에는 SHA-256 해시만 있습니다).

!API 키 현황 — 소유자와 키 이름, 앞자리, scope, 최근 사용과 상태](images/guide/admin-keys.png)

3.5 설정 화면과 설정 키

시스템 설정 화면은 자주 쓰는 것을 카드로 묶어 보여 주고(Keycloak OIDC 간편 연결, 사내 AI Gateway 간편 연결 ...), 그 아래에서 개별 키를 직접 다룰 수 있습니다. 값을 저장할 때마다 설정 스냅샷 revision 이 생기므로 **설정 버전** 목록에서 이전 상태로 되돌릴 수 있습니다.

!시스템 설정 — Keycloak OIDC 간편 연결 카드와 설정 검증·연결 테스트 단추](images/guide/admin-settings.png)

기본값이 있는 설정 키는 다음과 같습니다(`internal/settings/repository.go`). 비밀 설정으로 표시된 것은 저장한 뒤 화면에 다시 나오지 않습니다.

키	기본값	설명
<code>branding.product_name</code>	<code>kanpic</code>	화면에 표시할 제품명
<code>localization.locale</code>	<code>ko-KR</code>	기본 로케일
<code>localization.timezone</code>	<code>Asia/Seoul</code>	기본 시간대
<code>editor.autosave_batch_ms</code>	<code>250</code>	자동 저장 배치 간격(ms)
<code>editor.max_cells_per_operation</code>	<code>1000</code>	쓰기 요청당 최대 셀 수
<code>auth.oidc.enabled</code>	<code>false</code>	Keycloak OIDC 로그인 사용
<code>auth.oidc.issuer_url</code>	빈 값	Keycloak Realm Issuer URL
<code>auth.oidc.client_id</code>	<code>kanpic</code>	Keycloak Client ID
<code>auth.oidc.client_secret</code>	빈 값	Confidential Client Secret (비밀 설정)
<code>auth.oidc.ca_pem</code>	빈 값	사내 CA 인증서 PEM (비밀 설정)
<code>auth.oidc.scopes</code>	<code>openid, profile, email</code>	OIDC Scope
<code>auth.oidc.admin_roles</code>	<code>kanpic-admin</code>	관리자 권한으로 인정할 Keycloak Role
<code>auth.session_hours</code>	<code>8</code>	로그인 세션 유지 시간
<code>server.public_url</code>	빈 값	프록시 외부 공개 URL. 비우면 요청 Host 사용
<code>files.max_import_mb</code>	<code>20</code>	Import 파일 최대 크기(MB)
<code>files.max_image_mb</code>	<code>5</code>	시트에 넣는 이미지 한 장의 최대 크기 (MB)
<code>ai.enabled</code>	<code>false</code>	AI 기능 사용
<code>ai.gateway_url</code>	빈 값	사내 OpenAI 호환 LLM Gateway
<code>ai.model</code>	<code>kanpic-default</code>	AI 작업에 사용할 모델
<code>ai.api_key</code>	빈 값	LLM Gateway API Key (비밀 설정)
<code>ai.ca_pem</code>	빈 값	사내 LLM Gateway CA 인증서 PEM (비밀 설정)
<code>ai.timeout_seconds</code>	<code>30</code>	AI Gateway 요청 제한 시간(초)
<code>ai.max_input_cells</code>	<code>200</code>	AI 에 전달할 선택 범위 최대 셀 수

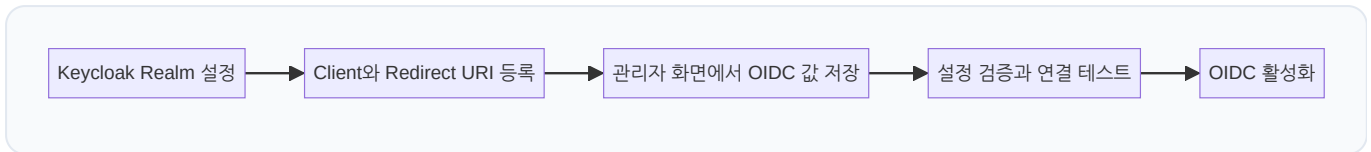
키	기본값	설명
<code>ai.max_changes</code>	100	AI 계획 한 건의 최대 변경 셀 수
<code>ai.max_output_tokens</code>	0	응답 최대 토큰. 0 이면 컨텍스트 길이에서 자동 계산
<code>ai.history_retention_days</code>	0	AI 호출 이력 보존 기간(일). 0 이면 계속 보관
<code>presentation.enabled</code>	false	선택 범위로 프레젠테이션 만들기 사용
<code>presentation.provider</code>	ptium	프레젠테이션 서비스 종류
<code>presentation.base_url</code>	빈 값	프레젠테이션 서비스 주소
<code>presentation.api_key</code>	빈 값	프레젠테이션 서비스 API Key (비밀 설정)
<code>presentation.timeout_seconds</code>	60	프레젠테이션 서비스 요청 제한 시간(초)
<code>presentation.default_template_id</code>	빈 값	기본 템플릿 ID. 비우면 서비스 기본 디자인
<code>presentation.max_cells</code>	5000	한 프레젠테이션이 읽을 최대 셀 수
<code>mail.enabled</code>	false	이벤트 알림 메일 발송 사용
<code>mail.smtp_host</code>	빈 값	사내 SMTP 서버 주소
<code>mail.smtp_port</code>	25	사내 릴레이 25, STARTTLS 587, TLS 465
<code>mail.security</code>	auto	auto, none, starttls, tls
<code>mail.username</code>	빈 값	비우면 인증 없이 발송
<code>mail.password</code>	빈 값	SMTP 비밀번호 (비밀 설정)
<code>mail.from_address</code>	빈 값	보내는 주소. 비우면 <code>kanpic@SMTP호스트</code>
<code>mail.from_name</code>	kanpic	보내는 사람 이름
<code>mail.base_url</code>	빈 값	메일 본문 링크에 쓰는 kanpic 주소
<code>mail.skip_tls_verify</code>	false	사실 인증서 SMTP 의 인증서 검증 생략
<code>mail.timeout_seconds</code>	10	SMTP 연결 제한 시간(초)
<code>mail.notify_share</code> · <code>notify_comment</code> · <code>notify_watch</code> · <code>notify_mention</code>	모두 true	이벤트별 발송 여부

키	기본값	설명
<code>notify_access_request</code>		
<code>analytics.enabled</code>	<code>false</code>	방문자 추적 코드 삽입 사용
<code>analytics.provider</code>	<code>none</code>	<code>none</code> , <code>ga4</code> , <code>gtm</code> , <code>matomo</code> , <code>custom</code>
<code>analytics.measurement_id</code>	빈 값	GA4 측정 ID(G-) 또는 GTM 컨테이너 ID(GTM-)
<code>analytics.matomo_url</code> · <code>analytics.matomo_site_id</code>	빈 값	Matomo 서버 주소와 사이트 ID
<code>analytics.custom_snippet</code>	빈 값	직접 입력하는 추적 코드(HTML)
<code>analytics.allowed_hosts</code>	빈 값	추적 코드가 접속할 추가 도메인. 쉼표로 구분
<code>analytics.include_admin</code>	<code>false</code>	관리자·개인 설정 화면에도 삽입
<code>analytics.placement</code>	<code>head</code>	삽입 위치: <code>head</code> 또는 <code>body</code>
<code>automation.enabled</code>	<code>false</code>	워크북 자동화 실행 사용
<code>automation.max_cells_per_run</code>	<code>1000</code>	자동화 실행 한 건의 최대 변경 셀 수
<code>automation.max_runs_per_hour</code>	<code>100</code>	워크북별 시간당 자동화 실행 한도
<code>automation.scheduler_poll_seconds</code>	<code>15</code>	스케줄 자동화 확인 주기(초)
<code>external.enabled</code>	<code>false</code>	수식의 외부 호출(WEBSERVICE, IMPORTDATA) 사용
<code>external.allowed_hosts</code>	빈 목록	외부 호출을 허용할 호스트. 비어 있으면 아무 데도 부르지 않음
<code>external.timeout_seconds</code>	<code>10</code>	외부 호출 한 건의 제한 시간(초)
<code>external.max_kb</code>	<code>1024</code>	외부 호출 응답의 최대 크기(KB)
<code>external.cache_seconds</code>	<code>300</code>	같은 주소의 응답을 다시 쓰는 시간(초)
<code>handoff.peers</code>	빈 목록	문서를 주고받을 사내 서비스. <code>서비스이름=오리진</code> 꼴. 비어 있으면 보내기 단추가 없고 아무 데서도 받지 않음
<code>sharing.max_link_access</code>	<code>anyone</code>	허용할 최대 링크 액세스 범위
<code>sharing.default_link_access</code>	<code>restricted</code>	새 워크북의 기본 링크 액세스
<code>mcp.enabled</code>	<code>true</code>	MCP Gateway 사용

키	기본값	설명
<code>observability.log_retention_days</code>	30	서버 로그 보존 일수

4. OIDC / Keycloak 연동 설정

kanpic은 기업용 SSO 구축을 위해 Keycloak과의 OIDC PKCE 인증을 지원합니다.



4.1 관리자 화면 설정 명세

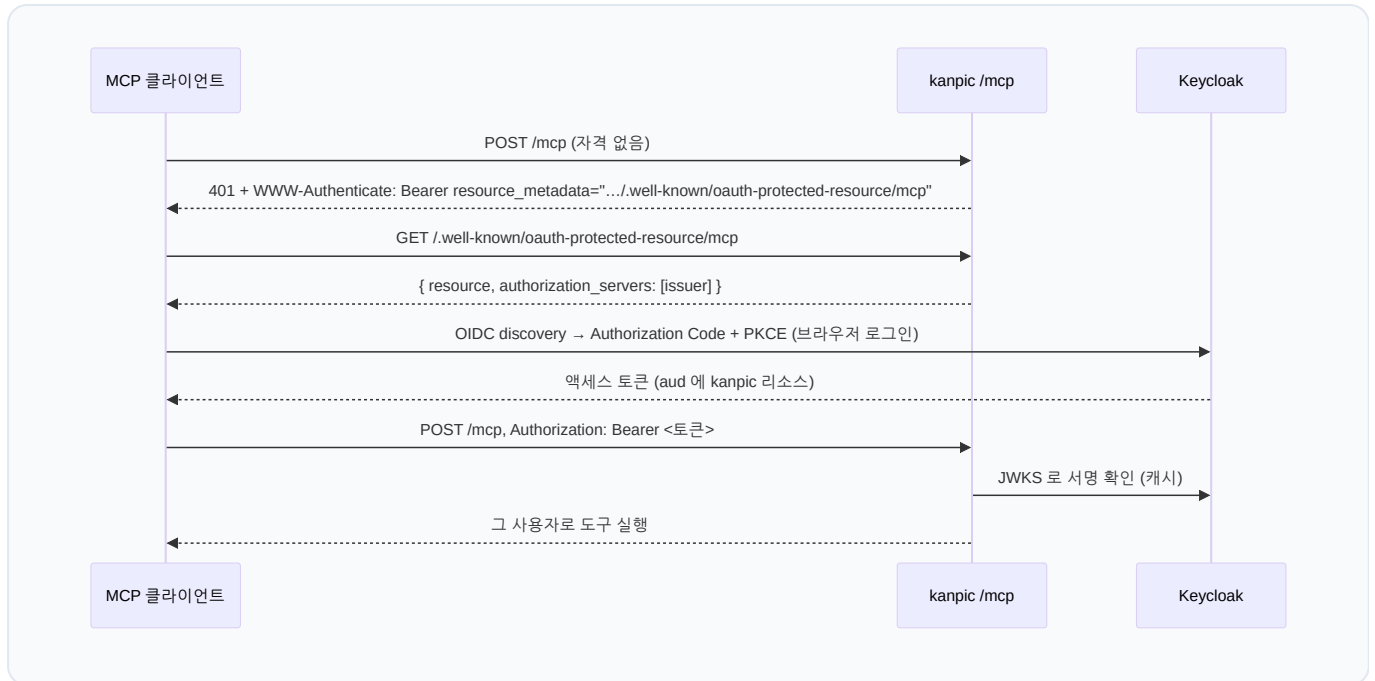
설정 키	기본값	설명
<code>auth.oidc.enabled</code>	false	검증과 연결 시험을 마친 뒤 SSO 로그인 활성화
<code>auth.oidc.issuer_url</code>	빈 값	Keycloak Realm Issuer URL
<code>auth.oidc.client_id</code>	kanpic	OIDC Client ID
<code>auth.oidc.client_secret</code>	빈 값	Public Client는 비우고 Confidential Client만 입력하는 비밀 설정
<code>auth.oidc.scopes</code>	openid, profile, email	요청할 OIDC scope 목록
<code>auth.oidc.admin_roles</code>	kanpic-admin	관리자 권한으로 인정할 Keycloak role 목록
<code>auth.oidc.mcp_enabled</code>	true	MCP 클라이언트가 Keycloak 액세스 토큰으로 <code>/mcp</code> 를 부르게 허용. OIDC 가 켜져 있을 때만 효력
<code>auth.oidc.mcp_audiences</code>	빈 목록	MCP 토큰의 <code>aud</code> 로 받아들이길 값. 비우면 Client ID 와 <code>/mcp</code> 주소
<code>auth.oidc.ca_pem</code>	빈 값	폐쇄망 사설 CA 인증서 PEM 비밀 설정
<code>server.public_url</code>	빈 값	리버스 프록시 외부 주소. 비우면 요청 Host 사용

각 저장·수정·삭제는 설정 스냅샷 revision을 생성합니다. **전체 검증**으로 필수값과 타입을 확인한 뒤 **연결 테스트**로 Issuer discovery와 PostgreSQL 상태를 시험합니다. 문제가 생기면 설정 버전 목록에서 이전 revision을 복원할 수 있습니다. 서버 시작에 필요한 환경 변수는 `POSTGRES_DSN` 하나이며, bootstrap 로그인 보호가 필요할 때만 `BOOTSTRAP_ADMIN_ID` 와 `BOOTSTRAP_ADMIN_PASSWORD` 를 함께 추가합니다.

4.2 MCP 클라이언트의 Keycloak OAuth 로그인

Claude, Cursor 같은 MCP 클라이언트는 API 키 대신 **사용자의 Keycloak 로그인**으로 `/mcp` 를 부를 수 있습니다. kanpic 은 MCP 인가 명세(2025-06-18)의 **OAuth 2.1 리소스 서버**로 동작하고, 인가 서버는 이미 쓰고 있는 Keycloak Realm 입니다. 사람이 키를

만들어 붙여 넣는 대신 브라우저에서 한 번 로그인하고, 토큰은 그 사람의 권한만큼 움직입니다.



Keycloak 쪽에서 할 일

MCP 클라이언트용 Client 를 만듭니다. Public client, Standard flow, PKCE [S256](#) 을 켜고 Redirect URI 에는 클라이언트 문서가 안내하는 값을 적습니다. 동적 클라이언트 등록(RFC 7591) 으로 스스로 등록하는 클라이언트를 쓰려면 Realm 의 *Client registration* › *Anonymous access policies* 에서 Trusted Hosts 를 그 클라이언트가 오는 곳으로 열어 둡니다.

토큰에 kanpic 을 받는 이로 적습니다. 그 Client(또는 그 Client 의 dedicated scope)에 Audience 매퍼를 붙여 *Included Custom Audience* 에 `/mcp` (예: `https://kanpic.example/mcp`) 를 넣거나, *Included Client Audience* 에 kanpic 의 Client ID 를 넣습니다. kanpic 은 `aud` 가 `auth.oidc.mcp_audiences` (비우면 Client ID 와 `/mcp` 주소) 중 하나와 정확히 같거나, `azp` 가 kanpic 의 Client ID 인 토큰만 받습니다. 다른 서비스용으로 발급된 토큰은 서명이 맞아도 거절됩니다.

(선택) 토큰을 좁힙니다. `workbook.read`, `range.read` 같은 kanpic scope 이름으로 Client Scope 를 만들어 그 Client 에 붙이면 토큰의 `scope` 클레임에 실리고, kanpic 은 그 토큰을 **그 scope 만 가진 API 키처럼** 다룹니다(`mcp.use` 는 따로 필요하지 않습니다). kanpic scope 가 하나도 없는 토큰은 사용자가 웹에서 로그인했을 때와 같은 권한으로 움직입니다 — 워크북 공유 규칙과 `auth.oidc.admin_roles` 판정 모두 그대로입니다.

kanpic 쪽에서 확인할 것

- `auth.oidc.enabled` 가 켜져 있어야 합니다. 토큰을 확인할 곳이 Issuer 이기 때문입니다.

`auth.oidc.mcp_enabled` 는 기본 `true` 이고, 끄면 v0.246.0 과 같이 API 키만 받습니다.

- 리버스 프록시 뒤라면 `server.public_url` 이 바깥 주소여야 합니다. 리소스 식별자와

메타데이터 주소가 이 값으로 만들어지고, Keycloak 매퍼에 적은 audience 와 같아야 합니다.

- `GET /api/v1/auth/config` 와 MCP 도구 `platform.auth.config` 가 `mcp_oauth_enabled`, `mcp_resource`, `mcp_resource_metadata_url` 을 알려 주므로 클라이언트에 적어 줄 값을 여기서 확인합니다.

- 토큰은 `/mcp` 에서만 받습니다. REST 와 WebSocket 은 그대로 세션 쿠키와 API 키만 씁니다.

- 검증 규칙: Issuer 의 JWKS 로 서명, `iss`, `exp`, `aud` / `azp` 를 확인하고 `typ` 이 `ID`

인 토큰(ID 토큰)은 액세스 토큰이 아니므로 거절합니다. 거절 이유는 서버 로그의 `mcp access token rejected` 에 남고, 클라이언트에는 `invalid_token` 만 나옵니다. Issuer discovery 와 키는 서버가 캐시하므로 호출마다 Keycloak 을 부르지 않습니다.

5. 사내 AI Gateway 설정과 안전 정책

관리자 콘솔의 **사내 AI Gateway** **간편 연결** 카드에서 OpenAI 호환 `/v1` Gateway를 설정합니다. 설정값은 환경 변수가 아니라 PostgreSQL의 관리 설정으로 저장되며, 다른 설정과 동일하게 변경 revision, 검증, 연결 테스트와 이전 버전 복원을 지원합니다.

설정 키	기본값	설명
<code>ai.enabled</code>	<code>false</code>	검증과 연결 테스트가 끝난 뒤 Workbook Agent 활성화
<code>ai.gateway_url</code>	빈 값	사내 vLLM 또는 OpenAI 호환 Gateway URL
<code>ai.model</code>	<code>kanpic-default</code>	요청에 사용할 배포 모델 이름
<code>ai.api_key</code>	빈 값	Gateway Bearer API Key 비밀 설정
<code>ai.ca_pem</code>	빈 값	폐쇄망 사설 CA 인증서 PEM 비밀 설정
<code>ai.timeout_seconds</code>	<code>30</code>	Gateway 호출 1회당 제한 시간
<code>ai.max_input_cells</code>	<code>200</code>	한 계획에 전달할 선택 범위 최대 셀 수
<code>ai.max_changes</code>	<code>100</code>	한 계획에서 허용할 최대 변경 셀 수
<code>ai.max_output_tokens</code>	<code>0</code>	응답 최대 토큰. <code>0</code> 이면 모델의 컨텍스트 길이에서 자동 계산
<code>ai.history_retention_days</code>	<code>0</code>	AI 호출 이력 보존 기간(일). <code>0</code> 이면 계속 보관

응답 길이는 기본적으로 서버가 정합니다. `GET /v1/models` 응답의 `max_model_len` (vLLM) 또는 `context_length` 를 읽어 컨텍스트 길이를 파악하고, 프롬프트 추정 토큰과 여유분을 뺀 값을 그 요청의 `max_tokens` 로 사용합니다. 값은 10분간 캐시하며, 컨텍스트 길이를 제공하지 않는 Gateway에서는 첫 호출이 8K 컨텍스트 안에 들도록 입력 크기를 반영한 보수적 상한을 쓰고 응답이 실제로 잘리면 상한을 키웁니다. `ai.max_output_tokens` 를 지정하면 작은 값도 포함해 그 상한이 항상 우선합니다. `ai.model` 에 적은 이름이 목록에 없고 모델이 하나뿐이면 그 모델을 사용합니다.

알림 메일 (SMTP)

콘솔의 **알림 메일** 화면에서 사내 SMTP를 연결하고 이벤트 알림 발송을 관리합니다. 사내 릴레이를 쓰는 경우 **SMTP 서버 주소만 넣으면 됩니다**. 사용자 이름을 비워 두면 인증 없이 발송하고, 포트는 25가 기본이며 465를 입력하면 별도 설정 없이 TLS로 접속합니다.

키	기본값	설명
<code>mail.enabled</code>	<code>false</code>	알림 메일 발송 사용
<code>mail.smtp_host</code>	빈 값	사내 SMTP 서버 주소
<code>mail.smtp_port</code>	<code>25</code>	사내 릴레이 25, STARTTLS 587, TLS 465
<code>mail.security</code>	<code>auto</code>	<code>auto</code> 는 서버가 STARTTLS를 광고할 때만 사용. <code>none</code> , <code>starttls</code> , <code>tls</code> 지정 가능
<code>mail.username</code>	빈 값	비우면 인증 없이 발송. 값이 있으면 PLAIN·LOGIN·CRAM-MD5 중 서버가 지원하는 방식 사용
<code>mail.password</code>	빈 값	SMTP 비밀번호(비밀 설정)
<code>mail.from_address</code>	빈 값	보내는 주소. 비우면 <code>kanpic@SMTP호스트</code>
<code>mail.from_name</code>	<code>kanpic</code>	보내는 사람 이름
<code>mail.base_url</code>	빈 값	메일 본문 링크에 쓰는 kanpic 주소
<code>mail.skip_tls_verify</code>	<code>false</code>	사실 인증서 SMTP의 인증서 검증 생략
<code>mail.timeout_seconds</code>	<code>10</code>	SMTP 연결 제한 시간
<code>mail.notify_share</code>	<code>true</code>	워크북 공유 알림
<code>mail.notify_comment</code>	<code>true</code>	댓글·답글 알림
<code>mail.notify_mention</code>	<code>true</code>	멘션 알림
<code>mail.notify_access_request</code>	<code>true</code>	엑세스 요청과 처리 결과 알림

연결 확인 은 릴레이에 접속해 인사(EHLO)까지만 하고 메일을 보내지 않습니다. **테스트 메일 보내기** 는 지정한 주소로 실제 메일을 한 통 보냅니다. 두 기능 모두 결과를 화면에 그대로 보여 주므로 방화벽이나 인증 문제를 바로 확인할 수 있습니다.

발송되는 이벤트는 다음과 같습니다.

- **워크북 공유**: 사용자 대상으로 공유하면 그 사람에게. 부서·역할 공유는 대상이 확정되지 않아 발송하지 않습니다.
- **댓글과 답글**: 워크북 소유자, 사용자 공유 대상, 같은 스레드 참여자에게. 작성자 본인은 제외합니다.
- **멘션**: `@사용자` 로 언급된 사람에게. 멘션 대상은 스레드 알림을 중복으로 받지 않습니다.
- **엑세스 요청**: 소유자와 공유 대상에게. 승인·거절 결과는 요청자에게.

메일은 요청 처리와 분리된 백그라운드에서 보내므로 SMTP가 느려도 화면이 기다리지 않습니다. 실패하면 2초 뒤 한 번 더 시도하고, 모든 시도는 **발송 이력** 표에 시각·이벤트·수신자·상태·오류와 함께 남습니다. 수신자 주소는 사용자 디렉터리의 이메일에서 찾으며, 이메일이 없는 계정은 조용히 건너뛸니다.

```
GET /api/v1/admin/mail/deliveries?status=sent|failed|queued&limit=100
POST /api/v1/admin/mail:test {"recipient":"admin@corp.example"}
```

다른 서비스와 문서 주고받기 (Handoff)

kanpic 은 사내 서비스 간 문서 넘기기 표준을 따릅니다. 편집기의 **파일 > 다른 서비스로 보내기** 를 고르면 사람이 파일을 내려받아 다시 올리는 대신, 받는 서비스의 `/handoff` 가 새 창에서 열리고 그쪽이 kanpic 에서 직접 받아 갑니다. 반대로 다른 서비스가 CSV·XLSX 를 kanpic 으로 보내면 새 워크북이 만들어지고 그 워크북으로 넘어갑니다.

- kanpic 은 `csv` 와 `xlsx` 를 보내고, `csv` 와 `xlsx` 를 받습니다.
- 서비스끼리 서로의 자격 증명을 들고 있지 않습니다. 넘기는 것은 **한 번만 쓸 수 있는 5분짜리 표(claim)** 이고, 표는 그 사용자가 읽을 수 있는(내보내기가 허용된) 그 문서 하나에만 묶입니다. 표 원문은 데이터베이스에도 서버 로그에도 남지 않습니다(해시만 둡니다).
- 받은 워크북에는 어디서 왔는지가 남습니다. 편집기 제목 아래에 **ptium 에서 받음** 처럼 허용 목록의 이름으로 보이고(마우스를 올리면 오리진·파일 이름·받은 시각), `GET /api/v1/workbooks/{workbookId}/handoff` 가 같은 것을 오리진·파일 이름·받은 사람·시각과 허용 목록의 이름(`service`)으로 답합니다. 그 서비스를 허용 목록에서 지우면 이름 대신 호스트로 보입니다.

허용 목록 설정

`source` 는 밖에서 들어오는 값입니다. 그대로 받아 오면 kanpic 이 사내 아무 주소나 대신 굵어 오는 도구가 되므로, **관리자가 `handoff.peers` 에 적은 오리진에서만 받고 없으면 아무것도 요청하지 않고 거절합니다.** 이 목록은 **설정** 화면의 `handoff.peers` (문자열 목록)에 둡니다. 기본값은 비어 있고, 비어 있는 동안에는 편집기에 보내기 단추가 보이지 않으며 어느 서비스에서 보낸 문서도 받지 않습니다 — 새로 설치한 곳에서는 아무것도 달라지지 않습니다.

한 줄에 서비스 하나를 `서비스이름=오리진` 꼴로 적습니다. 오리진은 `https://호스트[:포트]` 까지만이고 경로는 붙이지 않습니다.

```
ptium=https://ptium.intra, weekly=https://weekly.intra, kanpic=https://kanpic-staging.intra:8443
```

서비스 이름	보내기 단추에 보이는가	까닭
<code>ptium</code> , <code>kanpic</code>	보인다	CSV·XLSX 를 받는 서비스
<code>umm</code> , <code>muni</code> , <code>weekly</code>	보이지 않는다	CSV·XLSX 를 받지 않는다. 그쪽에서 kanpic 으로 보내는 것만 허용된다
이름 없이 오리진만	보이지 않는다	무엇을 받는지 알 수 없어 받기만 허용한다

받을 때는 다음을 지킵니다. 리다이렉트를 따라가지 않고, 25MB 를 넘는 본문은 중간에 끊으며, 30초 안에 오지 않으면 포기하고, 응답의 `Content-Type` 이 `text/csv` 나 XLSX 가 아니면 버립니다. 거절하면 사람이 읽을 수 있는 화면에 까닭(허용 목록에 없음·표 만료·형식·크기)이 나옵니다.

kanpic 이 표에 적는 자기 주소는 `server.public_url` 입니다. 리버스 프록시 뒤에 있다면 받는 서비스가 그 주소로 표를 받으려 오므로 프록시 바깥에서 닿는 주소를 적어야 합니다. 비워 두면 요청의 `Host` 를 씁니다.

방문자 추적 (Analytics)

콘솔의 **방문자 추적** 화면에서 웹사이트 방문자 데이터를 수집하는 자바스크립트를 넣습니다. 제공자를 고르고 식별자만 입력하면 삽입할 코드와 그 코드가 필요로 하는 콘텐츠 보안 정책(CSP)이 함께 만들어지므로, 정책을 따로 손볼 필요가 없습니다.

키	기본값	설명
<code>analytics.enabled</code>	<code>false</code>	추적 코드 삽입 사용
<code>analytics.provider</code>	<code>none</code>	<code>none</code> , <code>ga4</code> , <code>gtm</code> , <code>matomo</code> , <code>custom</code>
<code>analytics.measurement_id</code>	빈 값	GA4 측정 ID(<code>G-</code>) 또는 GTM 컨테이너 ID(<code>GTM-</code>)
<code>analytics.matomo_url</code>	빈 값	자체 호스팅 Matomo 주소
<code>analytics.matomo_site_id</code>	빈 값	Matomo 사이트 ID
<code>analytics.custom_snippet</code>	빈 값	직접 입력하는